

Outlook Support Team Impersonation

Ticket Overview

Ticket Number: SOC-14992

Date/Time Reported: 2023-11-01 / 09:04:01 UTC

Assigned Analyst: Jeremiah Tindana (Contractor at MockingCyber)

Affected Endpoint : N/A

Affected User: Dana Derringer

NB: The sample phishing email analyzed in this report (challenge1.eml) is a challenge material from TCM Security's SOC curriculum. All investigation, IOC extraction, and analysis in this report including the header review, IOC classification, and MITRE ATT&CK mapping, are my own independent work, not the course's own walkthrough or answer key. "MockingCyber" is a fictional consultancy name used for realistic case-report formatting; the ticket number and reported date/time are also fictional. All other names, addresses, and details are as presented in the challenge material.

Incident Summary

On November 1, 2023 at 9:04:01 AM, Mighty Solutions executive Dana Derringer (dderringer@mighty-solutions.net) reported receiving an email that seemed to suggest that her account had been disabled. However, she was still able to access her account and all its functions. She decided to report the email in question to the third-party security contractor, MockingCyber, for review.

Investigation

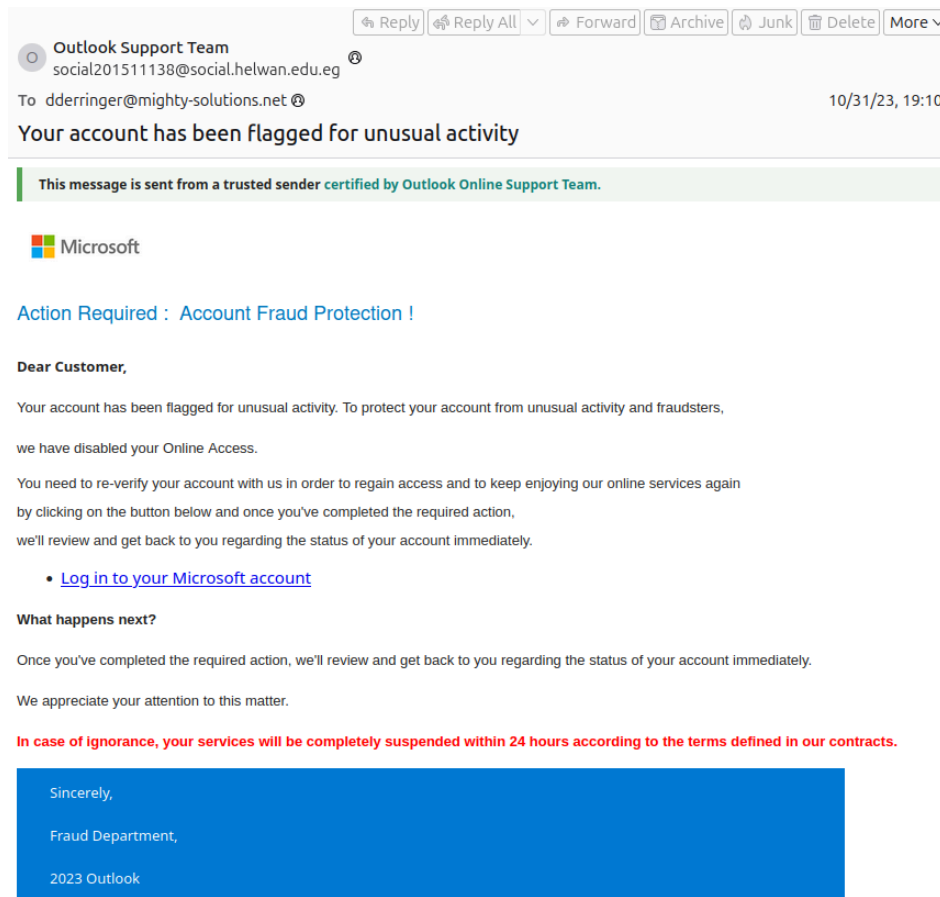
I began my investigation with a high-level view of the available cues, examining common phishing indicators such as pretexting, spoofing, and URL manipulation, and tactics such as intimidation, urgency, or FOMO. I opened the email file (challenge1.eml) using Thunderbird.

```

mockingcyber@SOC201: ~/Desktop/Investigations/Phishing$ thunderbird challenge1.eml
ln: failed to create symbolic link '/home/mockingcyber/snap/thunderbird/1170/.config/dconf/user': File exists
Gtk-Message: 00:37:38.084: Not loading module "atk-bridge": The functionality is provided by GTK natively. Please try to not load it.
[GFX1-]: glxtest: libpci missing

```

Picture 1. Thunderbird command to open email file.



Picture 2. Email file open in Thunderbird

With the email open, I reviewed its content. The message suggests to be from "Outlook Support Team" and displays a "flagged for unusual activity" warning, instructing the recipient to re-verify her account via a "Log in to your Microsoft account" link, with a threat that her services would be suspended within 24 hours if she failed to act. This mirrors a common intimidation/urgency tactic consistent with phishing. Also, the grammar is basic, unprofessional and poorly punctuated, which is typical of shabbily drafted phishing email messages.

Furthermore, several points appear inconsistent with a legitimate Microsoft/Outlook communication and warrant flagging.

- The sender's display name reads "**Outlook Support Team**," but the actual address is **social201511138@social.helwan.edu.eg**. This domain does not appear to be related to Microsoft. This display-name/address mismatch is consistent with spoofing.
- The banner reading "This message is sent from a trusted sender certified by Outlook Online Support Team" is unusual.
- The email is signed "2023 Outlook" / "Fraud Department," which does not match Microsoft's standard branding conventions.

Using the eioc.py tool, I extracted IPs, URLs, and headers from the email file.

```
mockingcyber@SOC201:~/Desktop/Investigations/Phishing$ python3 Tools/eioc.py challenge1.eml
Extracted IP Addresses:
=====
40[.]107[.]22[.]60 - Amsterdam, North Holland, NL, ISP: AS8075 Microsoft Corporation
10[.]152[.]26[.]146
0[.]232[.]205[.]92

Extracted URLs:
=====
hxxps[://][0[.]232[.]205[.]92[.]host[.]secureserver[.]net/lclbluewin08812/
hxxps[://][raw[.]githubusercontent[.]com/MalwareCube/SOC101/main/assets/01_Phishing_Analysis/mi
crosoft[.]jpg

Extracted Headers:
=====
Authentication-Results: spf=pass (sender IP is 40.107.22.60)
smtp.mailfrom=social.helwan.edu.eg; dkim=pass (signature was verified)
header.d=socialhelwanedu.onmicrosoft.com; dmarc=bestguesspass action=none
header.from=social.helwan.edu.eg; compauth=pass reason=109
Date: Tue, 31 Oct 2023 10:10:04 -0900
To: dderringer@mighty-solutions.net
From: Outlook Support Team <social201511138@social.helwan.edu.eg>
Subject: Your account has been flagged for unusual activity
Message-ID: <JMrByPl2c3HBo8SctKnJ5C5Gp64sPSSWk76p4sjQ@s6>
Return-Path: social201511138@social.helwan.edu.eg
X-Sender-IP: 40.107.22.60

Extracted Attachments:
=====
mockingcyber@SOC201:~/Desktop/Investigations/Phishing$
```

Picture 3. IOCs extracted from email file using eioc.py

The following IPs were extracted:

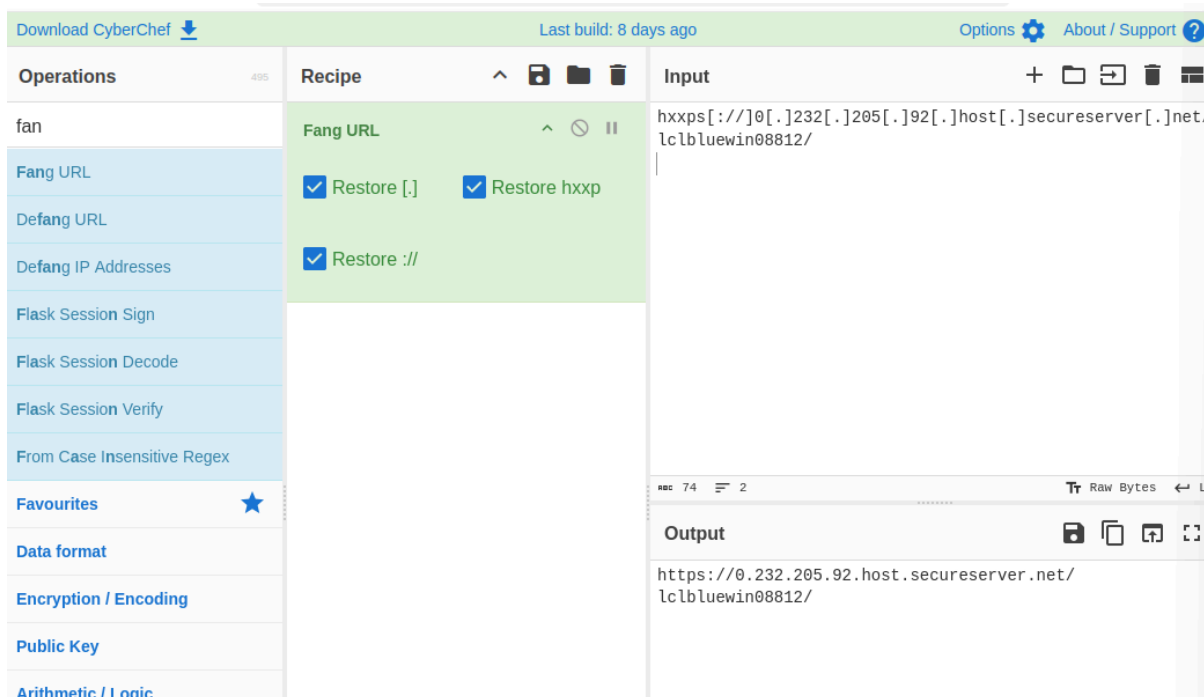
- 40.107.22.60 — Amsterdam, NL; ASN AS8075, Microsoft Corporation
- 10.152.26.146 — This is a private RFC1918 range which is consistent with internal Microsoft mail-routing infrastructure.
- 0.232.205.92 — appears in the hostname of the link that was sent to the user to supposedly be used to Microsoft account. This is a non-routable address as it sits in the 0.0.0.0/8 range.

Extracted URLs:

- `hxxps[://]0[.]232[.]205[.]92[.]host[.]secureserver[.]net/lclbluewin08812/` — the link presented to the recipient
- `hxxps[://]raw[.]githubusercontent[.]com/MalwareCube/SOC101/.../microsoft[.]jpg` — training-platform, unrelated to phishing.

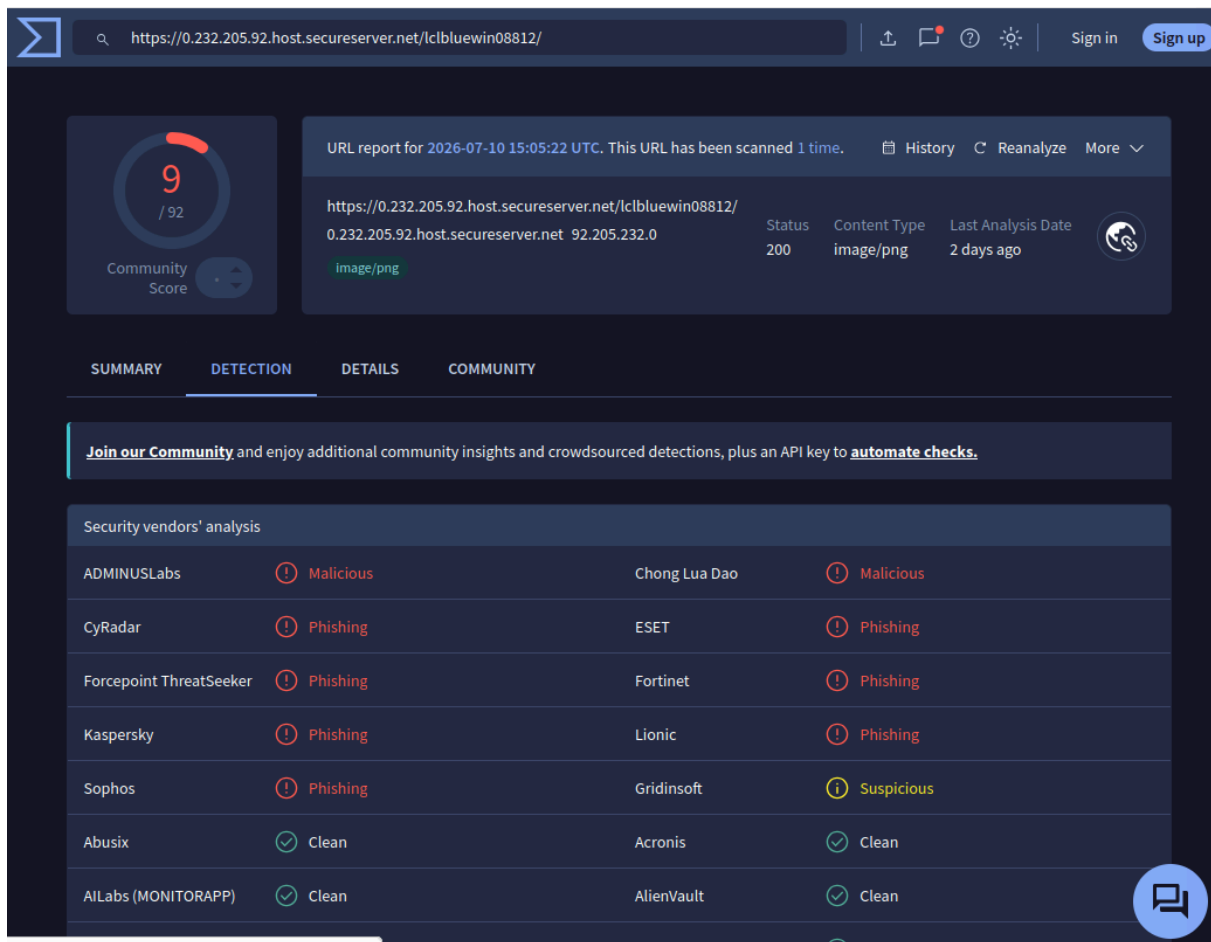
The extracted headers show an SPF pass for sender IP 40.107.22.60 and a DKIM pass, with the signature verified against `header.d=socialhelwanedu.onmicrosoft.com`. DMARC returned a result of `bestguesspass` rather than a true pass, which indicates that `social.helwan.edu.eg` does not publish a DMARC policy of its own — Microsoft is estimating alignment in the absence of a real record, rather than confirming it. The From field displays "Outlook Support Team" `social201511138@social.helwan.edu.eg`, and the Return-Path address matches the From address.

Using CyberChef, I fanged the extracted URL to make it usable for analysis.



Picture 4. Fanging URL using CyberChef

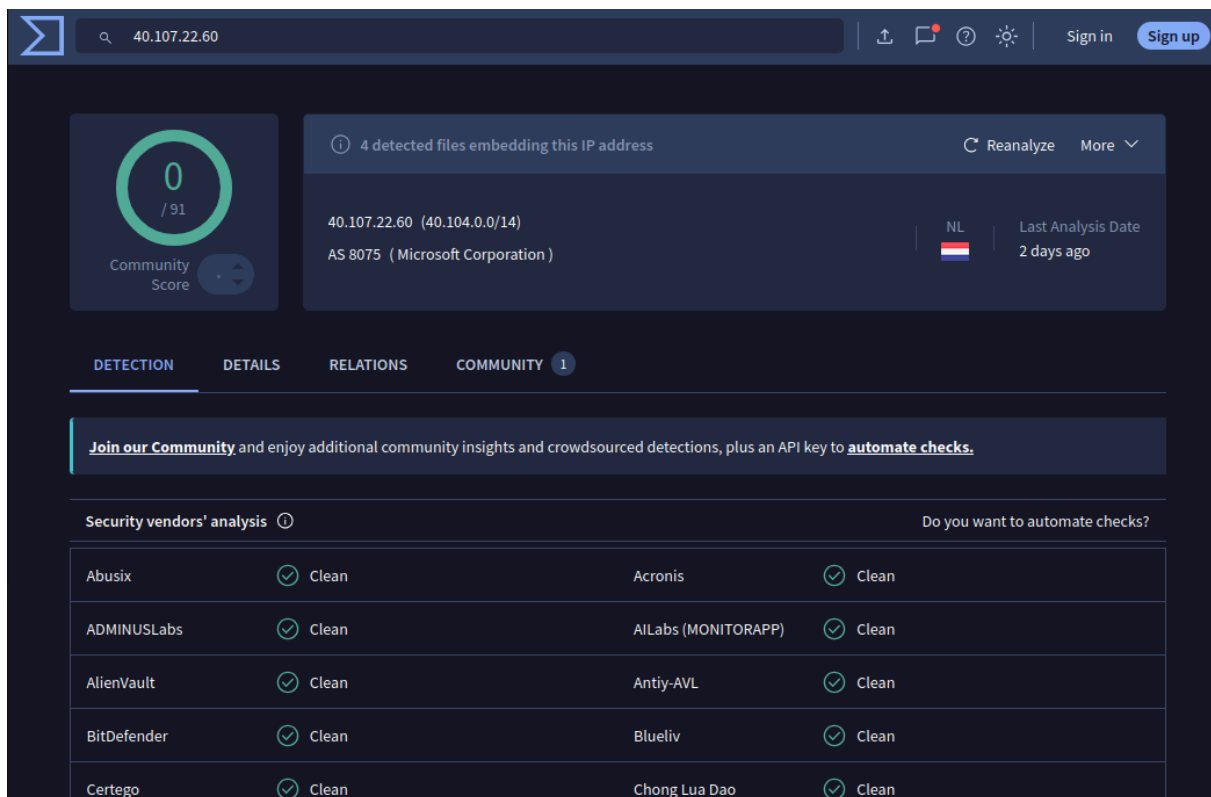
I looked up the URL on VirusTotal.



Picture 5. URL Virus Total lookup

The URL was flagged as malicious by 9 of 92 security vendors, including ADMINUSLabs and Chong Lua Dao (Malicious), and CyRadar, ESET, Forcepoint ThreatSeeker, Fortinet, Kaspersky, Lionic, and Sophos (Phishing). Gridinsoft returned a Suspicious classification. This URL has an active multi-vendor phishing detection footprint.

I looked up the sender IP address, 40.107.22.60, on VirusTotal.



Picture 6. Sender IP lookup

The IP returned a clean result (0/91 vendor detections), with a note that 4 files have been seen embedding this IP address. Given that this same IP already resolved to Microsoft's own outbound mail infrastructure (AS8075, Microsoft Corporation) per the SPF pass, a clean reputation result here isn't surprising.

Verdict

Based on the evidence gathered, this email is a phishing attempt impersonating Microsoft/Outlook account-security messaging.

The sender's display name, "Outlook Support Team," does not match the sending domain, social.helwan.edu.eg, which likely belongs to Helwan University in Egypt and has no relationship to Microsoft. The email uses urgency and threat language (account suspension within 24 hours) to pressure the recipient into clicking a verification link. That link does not lead to a Microsoft domain but to a GoDaddy-hosted subdomain (secureserver.net), and VirusTotal currently flags that URL as malicious or phishing across multiple security vendors.

The sender IP itself returned a clean VirusTotal result, but this cannot be treated as a greenlight, since the IP is shared Microsoft 365 sending infrastructure rather than

infrastructure controlled by the sender specifically.

MITRE ATT&CK Mapping

Initial Access — T1566.002 (Phishing: Spearphishing Link): The email delivered a link disguised as an urgent account-verification request.

Impersonation: The email spoofed a trusted brand (Microsoft/Outlook) using a mismatched display name and sending domain. This maps to Impersonation (T1656) as defined in ATT&CK v14–v18; in v19 this behavior was folded into the broader Social Engineering in Stealth (T1684) technique.

Indicators of Compromise (IOCs)

Address: social201511138@social[.]helwan[.]edu[.]eg

IP: 40[.]107[.]22[.]60 (shared Microsoft 365 outbound infrastructure, not attacker-exclusive)

URL: hxxps[:]//0[.]232[.]205[.]92[.]host[.]secureserver[.]net/lclbluewin08812/

Recommendations

1. Block the URL at the email gateway and web proxy level.
2. Confirm with Dana Derringer whether she clicked the link and, if so, whether she entered any credentials, so any compromised account can be reset.
3. Check whether other Mighty Solutions users received the same or similar email, to determine whether this was targeted or part of a broader campaign.
4. Consider reporting the sending account (social201511138@social.helwan.edu.eg) to Helwan University's IT/security team, since the evidence suggests this may be a compromised or misused legitimate mailbox rather than a purpose-built attacker domain.